



Application Security Assessment Report – Web Application

Application Name – Digitalized DPR

APM ID – 10464

BU Name – Renewable

Application Owner – Adithya Kumar (Adithya.Kumar1@adani.com)

BU CISO – Divan Raimagia (Divan.Raimagia@adani.com)

Business Owner – Rajiv Singhal (Rajiv.Singhal1@adani.com)

Analyst Name – Aastha Amin (aastha.amin@adani.com)

Confidential

V1.0 September 7, 2026

Disclaimer

This report, as well as any supplements, is **STRICTLY CONFIDENTIAL** and may be subject to one or more legal protections. It is just for the use of the report's designated addressee. This report is based on the IT environment that existed throughout the allowed assessment period.

The testing was carried out based on the experience of application security team and testing guidelines followed as per OWASP by the security team, this report does not represent a 100% guarantee or certification that all vulnerabilities have been identified and reported. Following reviews may reveal previously unknown facts or new vulnerabilities.

Table of Contents

Table of Contents	2
Confidentiality Statement.....	3
Introduction	3
Assessment Components	4
Objective	4
Scope	4
Scope Exclusions	4
Executive Summary	5
Attack Summary.....	5
Grey box Web Application Penetration Test Findings	6
1 – Unauthenticated Exposure of Swagger UI and OpenAPI Specification [Medium].....	6
2 – Arbitrary Local File Read [Medium]	8
3 – Security Header Missing [Low]	11
4 – Server Information Disclosure [Low]	12
5 – Information Disclosure / Verbose Error Message [Low].....	13
6 – Insufficient Minimum Password Length [Low].....	16
7 – Improper Session Management [Low]	17
Annexure	20
Vulnerabilities Severity Ratings	20

Confidentiality Statement

This document is the exclusive property of Adani Group. It contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of Adani.

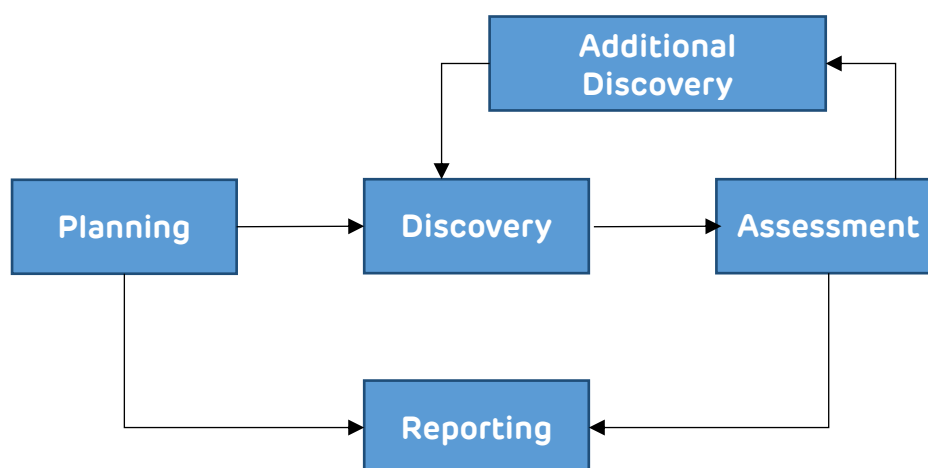
Adani Group may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Introduction

The Adani Application Security Team engaged to evaluate the security posture of **Digitalized DPR** application by performing external **Grey box** security testing from **September 1st, 2026**, to **September 7th, 2026**. All testing performed is based on the *OWASP Testing Guide (v5)*, and *customized testing frameworks*.

Adani Application Security Team follows 5 phases approach to perform application security assessment. Following is the list of phases:

- Planning – Initial Reconnaissance
- Discovery – Perform manual Grey box testing to identify potential vulnerabilities, weak areas, and exploits.
- Assessment – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.



Assessment Components

Objective

The objective of this exercise was to assess the security posture of the **Digitalized DPR** application from a Grey box perspective. This includes determining the application's ability to resist common attack patterns and identifying vulnerable areas in the internal or external interfaces that may be exploited by a malicious user.

Scope

Assessment Type	Application URL
Grey box Assessment	https://digitalized-dpr-uat.adani.com

Scope Exclusions

- Per rules of engagement, Adani application security team did not perform any Denial-of-Service attacks during testing.

Executive Summary

The Application Security Team evaluated the application security maturity through a Grey box penetration test from **September 1st, 2026**, to **September 7th, 2026**.

A total of **7** vulnerabilities were found during the application security assessment of **Digitalized DPR** Application. Below is the severity wise representation of discovered vulnerabilities.

Severity	Critical	High	Medium	Low
Vulnerability Count	0	0	2	5

Attack Summary

The following table describes the vulnerabilities which were found during the assessment by the Application Security Team.

Sr. No	Vulnerability	Severity	Business Impact
1	Unauthenticated Exposure of Swagger UI and OpenAPI Specification	Medium	Publicly exposed API documentation increases the visibility of the application's internal functionality. An attacker may leverage the disclosed API information to perform targeted attacks against exposed endpoints.
2	Arbitrary Local File Read	Medium	This information may be leveraged by attackers to facilitate further attacks.
3	Security Header Missing	Low	Implementing security headers helps to prevent against the number of injection attacks.
4	Server Information disclosure	Low	The vulnerability contributes to the information collection of reconnaissance phase for the attacker.
5	Information Disclosure / Verbose Error Message	Low	Exposure of internal database information may aid attackers in gathering intelligence about the application's underlying technologies and data structure.
6	Insufficient Minimum Password Length	Low	-
7	Improper Session Management	Low	An attacker who obtains a valid session token may be able to maintain unauthorized access to user accounts.

Grey box Web Application Penetration Test Findings

1 – Unauthenticated Exposure of Swagger UI and OpenAPI Specification [Medium]

Description:	The application exposes Swagger UI (/docs) and the OpenAPI specification file (/openapi.json) without requiring authentication. This allows an unauthenticated user to view the available API endpoints, request/response structures, supported HTTP methods and authentication mechanisms. Such information can assist an attacker in understanding the application's API architecture and identifying potential attack vectors.
Impact (Business):	Publicly exposed API documentation increases the visibility of the application's internal functionality. An attacker may leverage the disclosed API information to perform targeted attacks against exposed endpoints.
Impact (Technical):	An attacker can enumerate all documented APIs, understand request formats, identify sensitive parameters, and discover administrative or internal endpoints that may not be intended for public disclosure.
Impacted URL:	https://digitalized-dpr-uat.adani.com/docs https://digitalized-dpr-uat.adani.com/openapi.json
CVSS Score:	CVSS 5.3 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Remediation	Restrict access to Swagger UI and OpenAPI specification files to authenticated and authorized users only. Disable API documentation in production environments whenever possible. If documentation is required, implement access controls and ensure that sensitive endpoints, internal URLs, credentials, and debugging information are not included in the API specification.

Step to Reproduce:

1. Visit the impacted URL.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC

The screenshot shows a web browser displaying the API documentation for "Adani Flow - Digitalized DPR". The URL is <https://digitalized-dpr-uat.adani.com/docs>. The page features a header with the title "Adani Flow - Digitalized DPR" and version information "2.0.0" and "OAS 3.1". Below the title, it says "Backend API for the Digitalized DPR system". The main content area is titled "Authentication" and lists five API endpoints, each with a "POST" method and a brief description:

- POST** `/api/auth/register` Register
- POST** `/api/auth/login` Login
- POST** `/api/auth/swagger-login` Swagger Login
- POST** `/api/auth/refresh-token` Refresh Token
- POST** `/api/auth/logout` Logout

The screenshot shows the Swagger UI for the "Adani Flow - Digitalized DPR" API. The URL is digitalized-dpr-uat.adani.com/openapijson. The interface displays the following information:

- openapi:** "3.1.0"
- info:**
 - title:** "Adani Flow - Digitalized DPR"
 - description:** "Backend API for the Digitalized DPR system"
 - version:** "2.0.0"
- paths:** A list of API endpoints and their methods:
 - `/api/auth/register`: { post: [-] }
 - `/api/auth/login`: { post: [-] }
 - `/api/auth/swagger-login`: { post: [-] }
 - `/api/auth/refresh-token`: { post: [-] }
 - `/api/auth/logout`: { post: [-] }
 - `/api/auth/profile`: { get: [-] }
 - `/api/auth/supervisors`: { get: [-] }
 - `/api/auth/sitepms`: { get: [-] }
 - `/api/auth/email/login`: { post: [-] }
 - `/api/auth/email/login/verify`: { post: [-] }
 - `/api/auth/email/otp/resend`: { post: [-] }
 - `/api/auth/email/password/setup`: { post: [-] }
 - `/api/auth/email/password/setup/verify`: { post: [-] }
 - `/api/auth/email/password/change`: { post: [-] }
 - `/api/auth/email/password/change/verify`: { post: [-] }
 - `/api/auth/email/forgot-password`: { post: [-] }
 - `/api/auth/email/forgot-password/verify`: { post: [-] }
 - `/api/auth/email/forgot-password/reset`: { post: [-] }
 - `/api/auth/email/recovery-email`: { post: [-] }
 - `/api/auth/email/recovery-email/verify`: { post: [-] }
 - `/api/auth/email/password-status`: { get: [-] }
 - `/api/auth/email/password-strength`: { post: [-] }

2 – Arbitrary Local File Read [Medium]

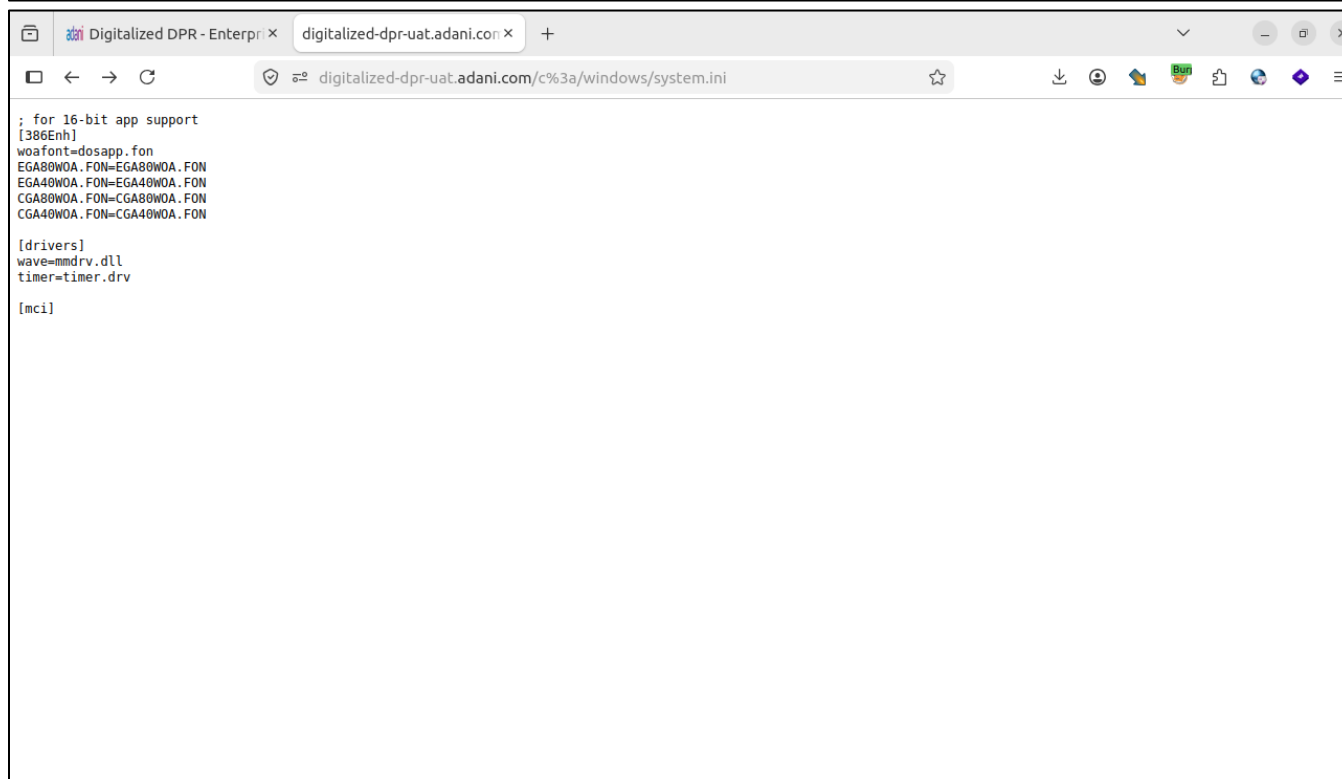
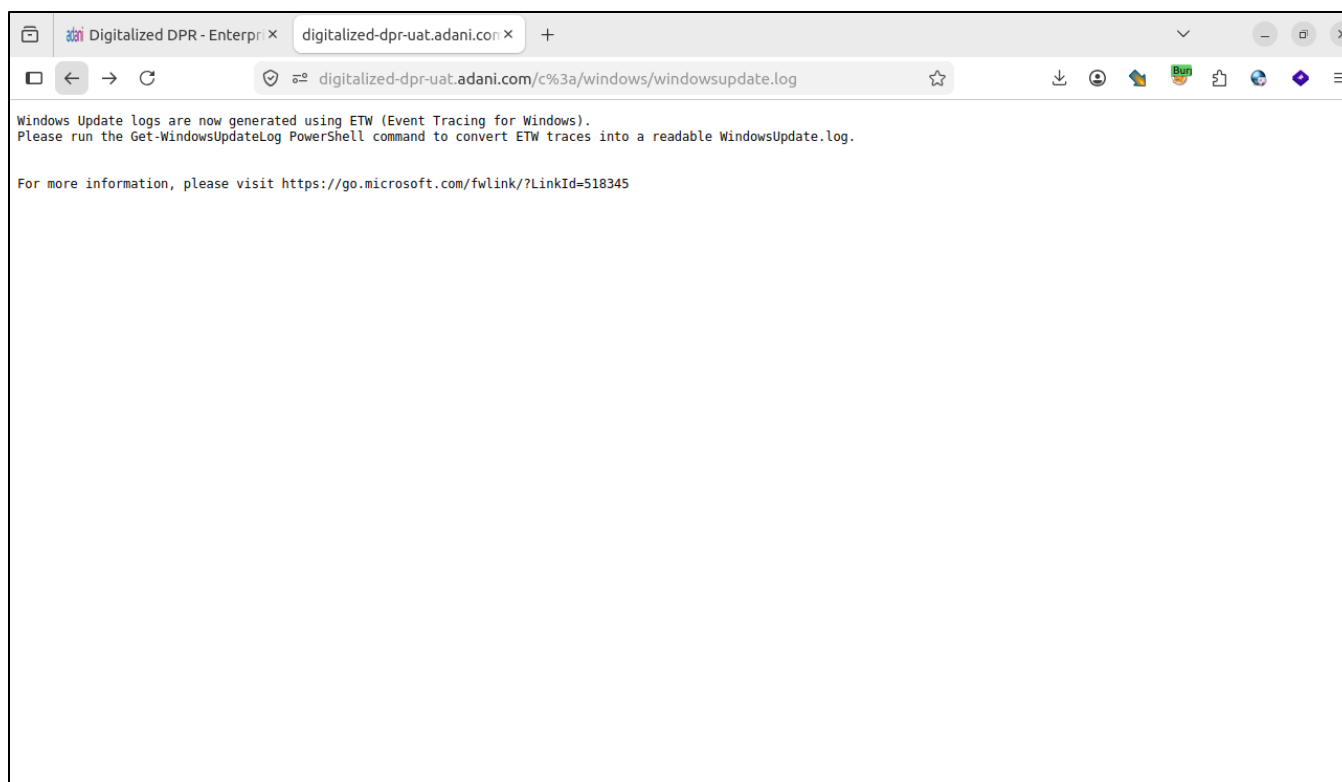
Description:	The application is vulnerable to Arbitrary Local File Read, allowing an unauthenticated user to access certain files from the underlying server. During testing, it was possible to retrieve local operating system files, including C:\Windows\win.ini, C:\Windows\system.ini, and C:\Windows\System32\drivers\etc\hosts.
Impact (Business):	This information may be leveraged by attackers to facilitate further attacks.
Impact (Technical):	An attacker can read files from the server's file system without authorization. While only non-sensitive Windows system files were successfully accessed during testing, the vulnerability demonstrates the existence of improper file access controls that may expose additional files if further exploitation paths are discovered.
Impacted URL:	https://digitalized-dpr- uat.adani.com/c%3a/windows/windowsupdate.log https://digitalized-dpr- uat.adani.com/c%3a/windows/system.ini <a href="https://digitalized-dpr-
uat.adani.com/c%3a/windows/system32/drivers/etc/hosts">https://digitalized-dpr- uat.adani.com/c%3a/windows/system32/drivers/etc/hosts
CVSS Score:	CVSS 5.3 /AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Remediation	Implement strict allowlist-based validation for file access operations and prevent user-controlled input from being used directly in file path processing. Restrict file access to approved directories only, normalize file paths before processing, and enforce the principle of least privilege on the application's file system permissions.

Step to Reproduce:

1. Visit the impacted URLs.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC



```

# Copyright (c) 1993-2009 Microsoft Corp.
#
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
#
# This file contains the mappings of IP addresses to host names. Each
# entry should be kept on an individual line. The IP address should
# be placed in the first column followed by the corresponding host name.
# The IP address and the host name should be separated by at least one
# space.
#
# Additionally, comments (such as these) may be inserted on individual
# lines or following the machine name denoted by a '#' symbol.
#
# For example:
#
#      102.54.94.97      rhino.acme.com      # source server
#      38.25.63.10      x.acme.com         # x client host

# localhost name resolution is handled within DNS itself.
#      127.0.0.1        localhost
#      ::1              localhost
# Added by Docker Desktop
10.212.151.15 host.docker.internal
10.212.151.15 gateway.docker.internal
# To allow the same kube context to work on the host and the container:
127.0.0.1 kubernetes.docker.internal
# End of section

```

```

; for 16-bit app support
[fonts]
[extensions]
[mci extensions]
[files]
[Mail]
MAPI=1

```

3 – Security Header Missing [Low]

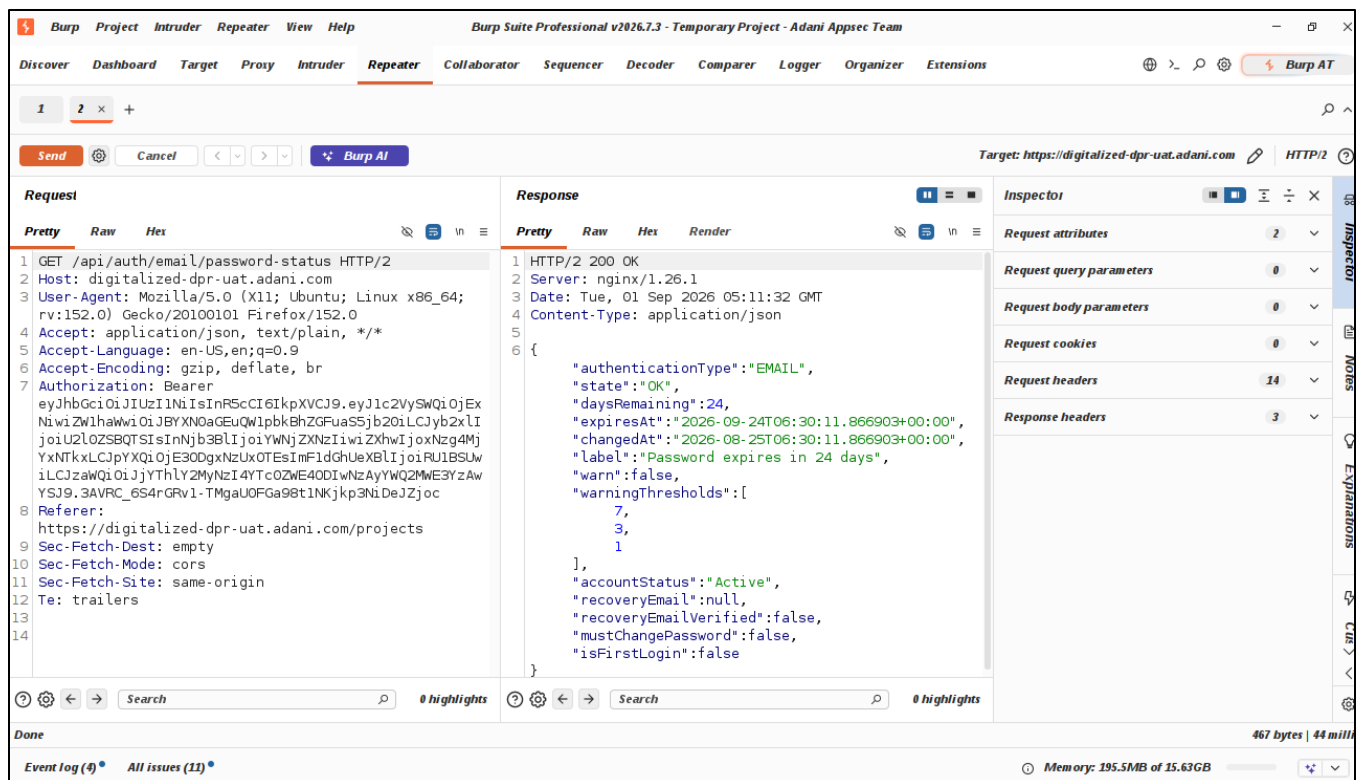
Description	During an assessment it was observed that the application has not configured some important HTTP security headers. HTTP security headers tell your browser how to behave when handling your website's content. Implementing security headers can help applications to prevent number of attacks.
Impact (Business)	Implementing security headers helps to prevent against number of injection attacks.
Impact (Technical)	The vulnerability can be used to ease the exploitation of vulnerabilities such as XSS and data injection.
Impacted URL	https://digitalized-dpr-uat.adani.com/
CVSS Score	-
Remediation	It is recommended to implement the Security Headers below. • Content-Security-Policy • X-Frame -Options • X-XXS-Protection • Strict-Transfer-Security-Policy

Step to Reproduce:

1. Open the application URL in a browser.
2. Examine the request and analyze the response. You will observe that the headers are missing.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC



4 – Server Information Disclosure [Low]

Description	Banner grabbing is a technique used to collect software, service, and version information from either remote or local servers like web servers, network hosts, etc. This method is generally implemented by administrators while inventing their systems or ethical hackers to run penetration tests to expose any vulnerabilities in a network.
Impact (Business)	The vulnerability contributes to the information collection of reconnaissance phase for the attacker.
Impact (Technical)	The application is revealing server information in response headers. Such information can help an attacker to search for known exploits associated with the version.
Impacted URL	<code>https://digitalized-dpr-uat.adani.com/</code>
CVSS Score	-
Remediation	It is recommended to not disclose server information in response header.

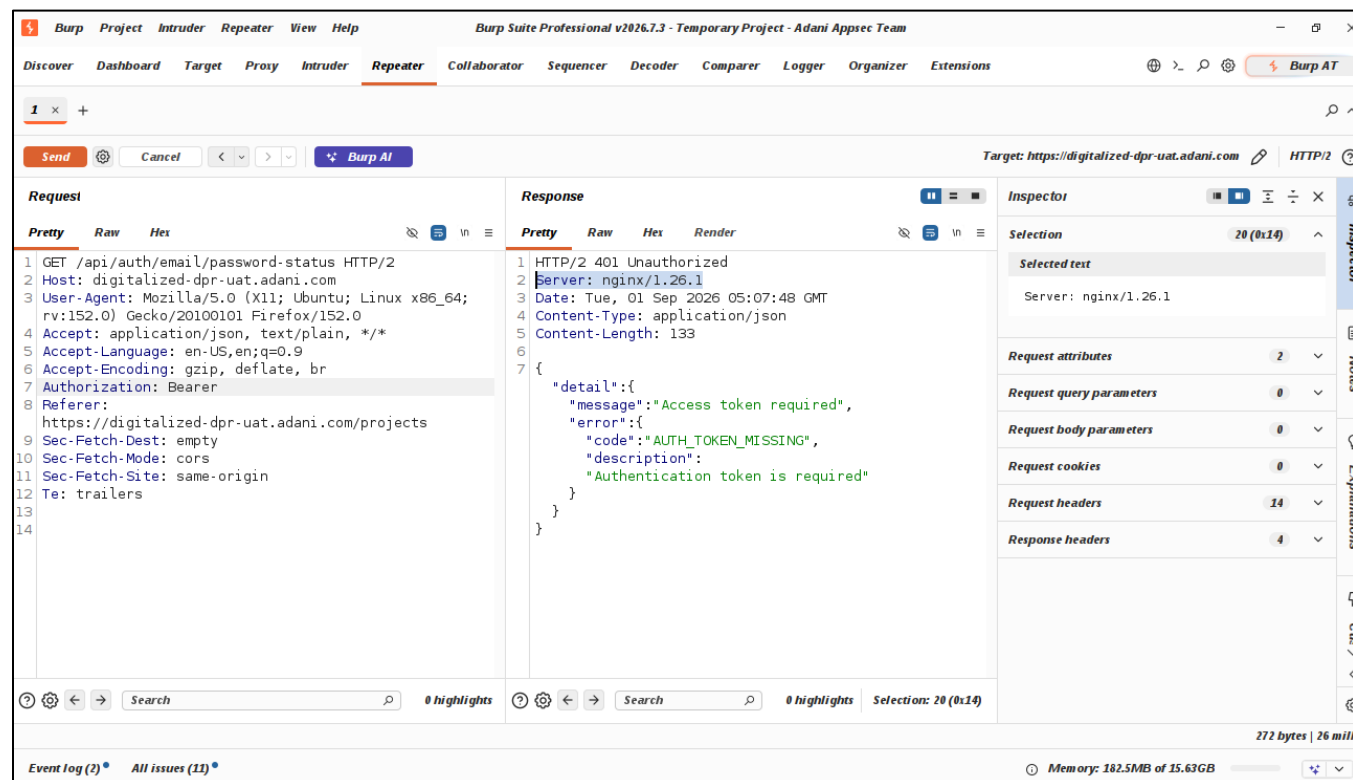
Step to Reproduce:

1. Visit the URL and Intercept the request.

2. Send the request to the repeater.
3. You will observe that the application is exposing the server information.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC



5 – Information Disclosure / Verbose Error Message [Low]

Description	The application discloses detailed backend database error messages to end users. Such information should not be exposed to users and may assist attackers in understanding the application's backend architecture.
Impact (Business)	Exposure of internal database information may aid attackers in gathering intelligence about the application's underlying technologies and data structure.
Impact (Technical)	The application exposes unhandled database exceptions containing sensitive implementation details, such as database constraints, column names, and data types. These disclosures assist attackers in fingerprinting the backend database and crafting more targeted attack payloads against the application.
Impacted URL	-
CVSS Score	-

Remediation	Implement proper exception handling and generic user-facing error messages. Detailed database errors should be logged securely on the server side and should never be returned to end users. Configure centralized error handling mechanisms to prevent leakage of internal application and database information.
--------------------	---

Step to Reproduce:

1. Login to the application.
2. Navigate to any functionality that accepts user input or object identifier.
3. Modify the input value or submit unexpected data.
4. Observe the application's response.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC

Burp Suite Professional v2026.7.3 - digitalized dr - Adani Appsec Team

Discover Dashboard Target Proxy **Intruder** **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions

1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 +

24 25 **privilege escalation** 27 28 x

Send Cancel < > Burp AI

Target: <https://digitalized-dpr-uat.adani.com> HTTP/2

Request
 Pretty Raw Hex

```

1 Si$InJvbGuiOiJtdXBlciBBZG1pbiIsInNjb3BlIjoIYWNjZkNzIi
2 wiZXhwIjoxNzg4NDk4Nzc5LjpyXQI0jE3ODg0MTIzNzksImFldGh
3 UeXBlIjoIRU1BSUwILCJzawQiOiI3NjRjNzcyMmFlNTE0OGY4YmE2
4 ZGM3Nzg5NzZjZjU3NSJ9.4iVZm_tk7Hjffwkd1zgXjli4GZChyD
5 _SJGY8pCx9I
6
7 Content-Length: 102
8 Origin: https://digitalized-dpr-uat.adani.com
9 Sec-Gpc: 1
10 Referer:
11 https://digitalized-dpr-uat.adani.com/superadmin
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17
18 {
19   "name": "Newuser",
20   "email": "aasthaamin2397@adani.com",
21   "password": "Aastha@6141Amin",
22   "role": "Supervisor"
23 }
          
```

Response
 Pretty Raw Hex Render

```

1 HTTP/2 400 Bad Request
2 Server: nginx/1.26.1
3 Date: Thu, 03 Sep 2026 05:22:16 GMT
4 Content-Type: application/json
5 Content-Length: 184
6 Access-Control-Allow-Credentials: true
7 Access-Control-Expose-Headers: Content-Length,
8 Content-Type
9 {
10   "detail": {
11     "message":
12       "Database insertion failure: duplicate key
13       value violates unique constraint \"users_em
14       ail_key\"\\nDETAIL: Key (email)=(aasthaamin
15       2397@adani.com) already exists."
16   }
17 }
          
```

Inspector
 Request attributes 2
 Request query parameters 0
 Request cookies 0
 Request headers 19
 Response headers 6

0 highlights 0 highlights

Done 423 bytes | 469 millis

Event log (6) All issues Memory: 189.8MB of 15.63GB

Burp Suite Professional v2026.7.3 - digitalized dr - Adani Appsec Team

Discover Dashboard Target Proxy **Intruder** **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions

1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 +

24 25 **privilege escalation** 27 28 29 30 31 x

Send Cancel < > Burp AI

Target: <https://digitalized-dpr-uat.adani.com> HTTP/2

Request
 Pretty Raw Hex

```

1 PUT /api/super-admin/projects/771 HTTP/2
2 Host: digitalized-dpr-uat.adani.com
3 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64;
4 rv:152.0) Gecko/20100101 Firefox/152.0
5 Accept: application/json, text/plain, */*
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/json
9 Authorization: Bearer
10 eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VySWQiOiJl
11 OCViZW1haWwiOiJsdXNoYWJ0LkRhbmRmdydxN0axLHQGFkYWSpLmNvb
12 SI$InJvbGuiOiJtdXBlciBBZG1pbiIsImV4cCI6MTc0NDUxNTY2NS
13 wiaWF0IjoxNzg4NDI5MjY1fQ.BCwm08B4gu9WY8rMm2kVTrHiPeaT
14 NJd8FqXhd_ySq6M
15 Content-Length: 173
16 Origin: https://digitalized-dpr-uat.adani.com
17 Sec-Gpc: 1
18 Referer:
19 https://digitalized-dpr-uat.adani.com/superadmin
20 Sec-Fetch-Dest: empty
21 Sec-Fetch-Mode: cors
22 Sec-Fetch-Site: same-origin
          
```

Response
 Pretty Raw Hex Render

```

1 HTTP/2 500 Internal Server Error
2 Server: nginx/1.26.1
3 Date: Thu, 03 Sep 2026 10:09:04 GMT
4 Content-Type: application/json
5 Content-Length: 345
6
7 {
8   "message": "Internal server error",
9   "error":
10     "operator does not exist: character varying = sm
11     allint\\nLINE 1: ...tus = $8, updated_at = CURREN
12     T_TIMESTAMP WHERE id = $9 RETUR...\\n
13
14     ^\\nHINT: No operator matches the given name an
15     d argument types. You might need to add explicit
16     type casts."
17 }
          
```

Inspector
 Request attributes 2
 Request query parameters 0
 Request cookies 0
 Request headers 19
 Response headers 4

0 highlights 0 highlights

Done 493 bytes | 33 millis

Event log (11) All issues (2) Memory: 268.9MB of 15.63GB

6 – Insufficient Minimum Password Length [Low]

Description	The application enforces password complexity requirements, including uppercase letters, lowercase letters, numbers, and special characters. However, the minimum password length is set to 9 characters, which does not comply with the organization's password policy requirement of a minimum 12-character password.
Impact (Business)	-
Impact (Technical)	-
Impacted URL	https://digitalized-dpr-uat.adani.com/
CVSS Score	-
Remediation	Enforce the rules below in password policy: • Should have at least 1 uppercase. • Should have at least 1 lowercase. • Should have at least 1 number. • Should have at least 1 non-alphanumeric character. • Choose minimum 12 characters of password.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC

Digitalized DPR - Enterpr x

digitalized-dpr-uat.adani.com/security/password-setup

adani

Create New Password

For your security, please create your own password before continuing.

Signed in as Ishita.Sailor@adani.com

New Password

....

PASSWORD STRENGTH

Weak

- × Minimum 9 characters
- × Uppercase letter
- ✓ Lowercase letter
- × Number
- × Special character

Confirm New Password

Create Password

7 – Improper Session Management [Low]

Description	The application issues session tokens remain valid for an extended period without expiring. During testing, a previously captured token was successfully reused on the following day to perform authenticated actions, indicating that the application does not adequately enforce session timeout or token expiration
Impact (Business)	An attacker who obtains a valid session token may be able to maintain unauthorized access to user accounts.
Impact (Technical)	The absence of proper token expiration allows previously issued authentication tokens to remain valid beyond their intended lifetime, enabling session hijacking and replay of authenticated requests.
Impacted URL	https://digitalized-dpr-uat.adani.com/
CVSS Score	-
Remediation	Implement appropriate token expiration mechanisms and server-side session validation, and ensure that tokens are invalidated after logout, inactivity, or a predefined timeout period based on organizational security requirements.

Step to Reproduce:

1. Login to the application using valid credentials.
2. Intercept an authenticated request using Burp Suite.
3. Note the session token (Bearer Token) used in the request.
4. Save the intercepted request in Burp Repeater.
5. Close the browser session or wait until the next day.
6. Replay the same request using the previously captured session token.
7. Observe that the application successfully processes the request and returns a valid response.

Exploitation Proof of Concept:

Below screenshots illustrate the steps to reproduce the PoC

The screenshot displays the Burp Suite Professional v2026.7.3 interface. The top menu bar includes options like Burp, Project, Intruder, Repeater, View, and Help. The main toolbar shows various tools such as Discover, Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, and Extensions. The target URL is set to https://digitalized-dpr-uat.adani.com.

The interface is divided into several panels. The top panel shows a list of requests, with the selected request being a POST to /superadmin. The middle panel displays the request and response details. The request is a POST to /superadmin with a Content-Type of application/json. The response is a 200 OK with a message: "Project updated successfully".

The bottom panel shows the request and response in raw format. The request is a POST to /superadmin with a Content-Type of application/json. The response is a 200 OK with a message: "Project updated successfully".

Annexure

Vulnerabilities Severity Ratings

The following table defines levels of severity and corresponding CVSS 3.1 score range that are used throughout the document to assess vulnerability and risk impact.

Rating	CVSS Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Medium	4.0-6.9	Vulnerabilities exist but are not directly exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.